

Software Requirements Specification (SRS) for Security Enhancement in SeedDMS

1. Introduction

1.1 Purpose

This document specifies the requirements for enhancing security in **SeedDMS**, ensuring **GDPR & HIPAA compliance**, protecting user data, and securing document storage and access.

1.2 Scope

The security enhancements will include:

- ✓ **End-to-End File Encryption** (at rest & in transit)
 - ✓ **Role-Based Access Control (RBAC) Improvements**
 - ✓ **Audit Logs for Compliance Tracking**
 - ✓ **Two-Factor Authentication (2FA) for User Logins**
 - ✓ **Secure File Uploads & Malware Scanning**
-

2. Functional Requirements

2.1 File Encryption (At Rest & In Transit)

- **Encrypt uploaded files** using **AES-256** before storing them
- Use **SSL/TLS** to secure file transfers
- Implement **automatic key rotation** for enhanced security

2.2 Role-Based Access Control (RBAC) Enhancements

- Restrict **file access based on roles** (Admin, Editor, Viewer)
- Introduce **document access expiration** (auto-revoke after X days)
- Enable **custom permissions per folder/document**

2.3 Audit Logs & Compliance Tracking

- Track **who accessed/modified/deleted** a document
- Store logs securely and **prevent tampering**
- Provide **exportable audit logs** for compliance reporting

2.4 Two-Factor Authentication (2FA)

- Support **OTP-based login verification** (via email or authenticator apps)
- Require **2FA for admin accounts by default**

2.5 Secure File Uploads & Malware Scanning

- Scan uploaded files for **viruses and malware**
 - Restrict **executable file uploads** (.exe, .sh, .bat)
 - Set a **max file size limit** to prevent DoS attacks
-

3. Non-Functional Requirements

3.1 Performance

- File encryption **should not impact upload/download speed significantly**
- Audit logs should be stored efficiently to prevent performance issues

3.2 Security

- Encrypt sensitive **user data** in the database
- Use **secure password hashing** (bcrypt or Argon2)
- Prevent **SQL injection & XSS attacks**

3.3 Compliance

- Ensure SeedDMS meets **GDPR & HIPAA data protection standards**
- Logs must be **retained for a configurable period**